

Gym Backend

Техническая документация REST API

Версия 0.1.0 · Python / FastAPI

Май 2026

Содержание

1. Общее описание
2. Технологический стек
3. Аутентификация и безопасность
4. Роли пользователей
5. Конфигурация (переменные окружения)
6. Эндпоинты: Аутентификация `/api/v1/auth`
7. Эндпоинты: Пользователь `/api/v1/me`
8. Эндпоинты: Ресурсы `/api/v1/resources`
9. Эндпоинты: Планы `/api/v1/plans`
10. Эндпоинты: Заказы `/api/v1/orders`
11. Эндпоинты: Платежи `/api/v1/payments`
12. Эндпоинты: Клуб — клиент `/api/v1/gym`
13. Эндпоинты: Клуб — тренер `/api/v1/gym/trainer`
14. Эндпоинты: Клуб — администратор `/api/v1/gym/admin`
15. Эндпоинты: Системный администратор `/api/v1/admin`
16. Модели данных
17. Фоновые задачи (Celery)
18. Проверка здоровья сервиса

1. Общее описание

Gym Backend — асинхронный REST API на базе FastAPI для управления фитнес-клубом. Система поддерживает регистрацию и аутентификацию пользователей через Telegram и номер телефона, продажу абонементов, запись на групповые занятия, расчёт скидок, управление посещаемостью тренером и административную панель.

Базовый URL:

```
https://api/v1
```

Проверка здоровья:

```
GET /health -> {"status": "ok"}
```

Все ответы возвращаются в формате JSON. Мутирующие запросы (POST, PATCH, PUT, DELETE) требуют сессионного cookie и заголовка X-CSRF-Token.

2. Технологический стек

FastAPI >= 0.115	Асинхронный веб-фреймворк
SQLAlchemy 2.x + Alembic	Async ORM и миграции базы данных
PostgreSQL	Основная реляционная СУБД (драйвер psycopg 3)
Redis	Хранилище сессий, брокер и бэкенд результатов Celery
Celery >= 5.4	Асинхронная очередь фоновых задач
Pydantic v2	Валидация данных и схемы запросов/ответов
Uvicorn	ASGI-сервер
pytz / python-dateutil	Работа с временными зонами клуба

3. Аутентификация и безопасность

3.1 Сессионная аутентификация

После успешного входа сервер устанавливает два HttpOnly-cookie:

sid — идентификатор сессии в Redis, TTL: 1 час (настраивается SESSION_TTL_SECONDS).

refresh_token — токен обновления, TTL: 30 дней (REFRESH_TOKEN_TTL_SECONDS).

3.2 CSRF-защита

Все мутирующие запросы проверяют заголовок X-CSRF-Token. Токен возвращается в поле csrf_token тела ответа при логине и регистрации.

3.3 Telegram-аутентификация

Поддерживается Telegram Login Widget. Клиент передаёт payload виджета в поле telegram_auth запроса. Сервер проверяет HMAC-подпись с использованием TELEGRAM_BOT_TOKEN и допустимый возраст подписи (по умолчанию 24 ч).

3.4 Rate Limiting

Эндпоинты /auth/login и /auth/register защищены ограничением через Redis: 5 попыток за 60 секунд на идентификатор (телефон / Telegram ID / IP).

3.5 Подпись webhook

Входящие webhook-запросы проверяются по заголовку X-Payment-Signature (HMAC-SHA256 с ключом WEBHOOK_SECRET).

4. Роли пользователей

Каждый пользователь имеет одну роль, влияющую на доступные эндпоинты.

Роль	Значение	Описание
user	"user"	Обычный клиент. Доступ к /gym/*, /me, /resources, /plans, /orders, /payments/simulate.
trainer	"trainer"	Тренер. Дополнительно: /gym/trainer/* — расписание, отметка посещаемости, заявки на отсутствие.
admin	"admin"	Администратор. Дополнительно: /gym/admin/* — типы занятий, пользователи, отчёты. Telegram-администраторы из ADMIN_TELEGRAM_IDS получают пожизненный доступ ко всем ресурсам.

5. Конфигурация (переменные окружения)

Конфигурация загружается из файла `.env` в корне бэкенда. Все параметры имеют значения по умолчанию.

DATABASE_URL	postgresql+psycopg://postgres:postgres@localhost:5432/gym
REDIS_URL	redis://localhost:6379/0 (сессии)
SESSION_TTL_SECONDS	3600 (1 час)
REFRESH_TOKEN_TTL_SECONDS	2592000 (30 дней)
SECURE_COOKIES	true (HttpOnly + Secure флаги)
SAME_SITE	lax
CORS_ORIGINS	http://localhost:3000 (через запятую)
WEBHOOK_SECRET	change-me — секрет подписи webhook
TELEGRAM_BOT_TOKEN	обязателен для Telegram-аутентификации
TELEGRAM_AUTH_MAX_AGE_SECONDS	86400 (24 ч)
ADMIN_SECRET	секрет для <code>/admin/*</code> и <code>/auth/dev-login</code>
ADMIN_TELEGRAM_IDS	Telegram ID администраторов через запятую
LOGIN_RATE_LIMIT	5 (макс. попыток за окно)
REGISTER_RATE_LIMIT	5
RATE_LIMIT_WINDOW_SECONDS	60
RESOURCE_CACHE_TTL_SECONDS	300
CELERY_BROKER_URL	redis://localhost:6379/1
CELERY_RESULT_BACKEND	redis://localhost:6379/2
CLUB_TIMEZONE	Europe/Moscow
SESSION_GENERATION_HORIZON_WEEKS	6 (горизонт генерации занятий)
ABSENCE_MIN_HOURS_BEFORE	2 (мин. часов до занятия для заявки)
ABSENCE_TIMEOUT_POLICY	auto_approve / auto_reject
FRONTEND_URL	http://localhost:3000 (redirect в admin-login)
API_PREFIX	/api/v1

6. Эндпоинты: Аутентификация

Базовый путь: `/api/v1/auth`

Метод	Путь	Описание	Доступ
POST	/auth/register	Регистрация. Создаёт пользователя и сессию.	Публичный
POST	/auth/login	Вход по телефону или Telegram-виджету.	Публичный
POST	/auth/logout	Завершение текущей сессии.	Сессия + CSRF
POST	/auth/refresh	Ротация сессии и refresh-токена.	Сессия + CSRF
GET	/auth/admin-login	Вход от имени любого пользователя (redirect в UI).	ADMIN_SECRET
POST	/auth/dev-login	Dev-вход по телефону без пароля (только разработка).	X-Admin-Secret

POST /auth/register — тело запроса

Поле	Тип	Обяз.	Описание
telephone	string	Нет	Номер телефона
telegram_auth	object	Нет	Payload Telegram Login Widget
first_name	string	Нет	Имя
last_name	string	Нет	Фамилия
age	integer	Нет	Возраст
gender	string	Нет	Пол

Обязательно хотя бы одно из: `telephone` или `telegram_auth`.

Ответ AuthResponse — общий для login / register / refresh

Поле	Тип	Обяз.	Описание
user_id	UUID	—	Уникальный идентификатор пользователя
telephone	string null	—	Номер телефона
telegram_id	string null	—	Telegram ID
first_name	string null	—	Имя
last_name	string null	—	Фамилия
age	int null	—	Возраст

Поле	Тип	Обяз.	Описание
gender	string null	—	Пол
role	string	—	user / trainer / admin
csrf_token	string	—	CSRF-токен для последующих мутирующих запросов

7. Эндпоинты: Пользователь

Базовый путь: /api/v1

Метод	Путь	Описание	Доступ
GET	/me	Профиль текущего пользователя.	Сессия
PATCH	/me	Частичное обновление профиля.	Сессия + CSRF
GET	/me/accesses	Список активных прав доступа (AccessGrant).	Сессия

PATCH /me — все поля опциональны

Поле	Тип	Обяз.	Описание
first_name	string	Нет	Имя
last_name	string	Нет	Фамилия
age	integer	Нет	Возраст
gender	string	Нет	Пол

8. Эндпоинты: Ресурсы

Базовый путь: `/api/v1/resources`

Ресурс — защищённый контент, доступ к которому предоставляется через AccessGrant после покупки плана.

Метод	Путь	Описание	Доступ
GET	/resources	Список всех активных ресурсов.	Публичный
GET	/resources/{slug}	Информация о ресурсе по slug.	Публичный
GET	/resources/{slug}/content	Защищённый контент ресурса.	Сессия + AccessGrant

Модель ResourceRead

Поле	Тип	Обяз.	Описание
id	UUID	—	Идентификатор
slug	string	—	Уникальный slug (URL-friendly)
title	string	—	Название
description	string	—	Описание
is_active	boolean	—	Активен ли

9. Эндпоинты: Планы

Базовый путь: `/api/v1`

Планы — тарифы подписки, привязанные к ресурсу. Типы длительности: 1m, 3m, 6m, lifetime.

Метод	Путь	Описание	Доступ
GET	<code>/plans</code>	Список активных планов. Фильтр: <code>?resource_slug=</code> .	Публичный

Модель PlanRead

Поле	Тип	Обяз.	Описание
<code>id</code>	UUID	—	Идентификатор
<code>resource_id</code>	UUID	—	Ресурс
<code>code</code>	string	—	Код плана
<code>title</code>	string	—	Название
<code>duration_type</code>	string	—	1m / 3m / 6m / lifetime
<code>duration_months</code>	integer null	—	Количество месяцев (null для lifetime)
<code>price_amount</code>	decimal	—	Цена
<code>currency</code>	string	—	Валюта (USD по умолчанию)

10. Эндпоинты: Заказы

Базовый путь: /api/v1

Метод	Путь	Описание	Доступ
POST	/orders	Создать заказ на покупку плана. Статус: pending.	Сессия + CSRF

POST /orders — тело запроса

Поле	Тип	Обяз.	Описание
resource_id	UUID	Да	Идентификатор ресурса
plan_id	UUID	Да	Идентификатор плана
provider	string	Да	Платёжный провайдер: click / payme

Модель OrderRead

Поле	Тип	Обяз.	Описание
id	UUID	—	Идентификатор заказа
user_id	UUID	—	Пользователь
resource_id	UUID	—	Ресурс
plan_id	UUID	—	План
provider	string	—	Провайдер
status	string	—	pending / paid / failed / refunded
created_at	datetime	—	Дата создания

11. Эндпоинты: Платежи

Базовый путь: `/api/v1/payments`

Метод	Путь	Описание	Доступ
POST	<code>/payments/simulate</code>	Симуляция оплаты (dev). Через 5 сек выдаёт AccessGrant.	Сессия + CSRF
POST	<code>/payments/webhook</code>	Webhook от платёжной системы. Проверяет подпись HMAC.	X-Payment-Signature

POST `/payments/simulate` — тело запроса

Поле	Тип	Обяз.	Описание
<code>order_id</code>	UUID	Да	ID заказа со статусом pending
<code>provider</code>	string	Да	click / payme

POST `/payments/webhook` — тело запроса

Поле	Тип	Обяз.	Описание
<code>provider</code>	string	Да	Провайдер платежа
<code>event_id</code>	string	Да	Уникальный ID события (идемпотентность)
<code>event_type</code>	string	Да	Тип события
<code>order_id</code>	UUID	Да	ID заказа

После успешного webhook создаётся AccessGrant. Celery-задача обрабатывает событие в фоне. Операция идиempотентна.

12. Эндпоинты: Клуб — клиент

Базовый путь: `/api/v1/gym`

Метод	Путь	Описание	Доступ
GET	<code>/gym/class-types</code>	Список активных типов занятий.	Сессия
GET	<code>/gym/class-types/{id}</code>	Детальная информация о типе занятия.	Сессия
POST	<code>/gym/subscriptions/preview</code>	Предварительный расчёт стоимости абонемента.	Сессия
POST	<code>/gym/subscriptions</code>	Создать и оплатить абонемент.	Сессия
GET	<code>/gym/subscriptions</code>	Список абонементов текущего пользователя.	Сессия
GET	<code>/gym/subscriptions/{id}/sessions</code>	Занятия по абонементу (<code>?upcoming_only=true</code>).	Сессия
POST	<code>/gym/payments/webhook</code>	Webhook активации абонемента (<code>succeeded / failed</code>).	Публичный
GET	<code>/gym/bookings</code>	Список бронирований пользователя.	Сессия
GET	<code>/gym/credits</code>	Список скидочных кредитов.	Сессия
POST	<code>/gym/absence-requests</code>	Подать заявку на отсутствие (не позднее N ч до занятия).	Сессия
GET	<code>/gym/absence-requests</code>	Список заявок на отсутствие пользователя.	Сессия
GET	<code>/gym/schedule</code>	Расписание со всеми деталями для календаря.	Сессия

POST `/gym/subscriptions/preview` и POST `/gym/subscriptions` — тело запроса

Поле	Тип	Обяз.	Описание
<code>class_type_id</code>	UUID	Да	ID типа занятия
<code>period_type</code>	string	Да	<code>current_month_rest / next_month / next_3_months / next_6_months</code>
<code>provider</code>	string	Да	Платёжный провайдер (только для create)
<code>provider_txn_id</code>	string	Да	ID транзакции у провайдера (только для create)

POST `/gym/absence-requests` — тело запроса

Поле	Тип	Обяз.	Описание
booking_id	UUID	Да	ID бронирования
note	string	Нет	Комментарий / причина отсутствия

Заявка подаётся не позднее чем за ABSENCE_MIN_HOURS_BEFORE часов до начала занятия.

13. Эндпоинты: Клуб — тренер

Базовый путь: `/api/v1/gym/trainer`

Метод	Путь	Описание	Доступ
GET	<code>/gym/trainer/sessions/upcoming</code>	Предстоящие занятия тренера.	Тренер
GET	<code>/gym/trainer/sessions/past</code>	Прошедшие занятия тренера.	Тренер
GET	<code>/gym/trainer/sessions/{id}/participants</code>	Список участников занятия (только своё).	Тренер
POST	<code>/gym/trainer/sessions/{id}/attendance</code>	Отметить посещаемость. Статус сессии: COMPLETED.	Тренер
GET	<code>/gym/trainer/absence-requests</code>	Очередь ожидающих заявок на отсутствие.	Тренер

POST `/gym/trainer/sessions/{id}/attendance` — тело запроса (массив)

Поле	Тип	Обяз.	Описание
<code>booking_id</code>	UUID	Да	ID бронирования
<code>attended</code>	boolean	Да	Присутствовал ли участник

14. Эндпоинты: Клуб — администратор

Базовый путь: `/api/v1/gym/admin`

Метод	Путь	Описание	Доступ
POST	<code>/gym/admin/materialize-sessions</code>	Запустить генерацию занятий на N недель вперёд.	Админ
GET	<code>/gym/admin/class-types</code>	Все типы занятий (<code>?include_inactive=true</code>).	Админ
POST	<code>/gym/admin/class-types</code>	Создать тип занятия.	Админ
GET	<code>/gym/admin/class-types/{id}</code>	Детали типа занятия.	Админ
PATCH	<code>/gym/admin/class-types/{id}</code>	Обновить тип занятия.	Админ
DELETE	<code>/gym/admin/class-types/{id}</code>	Деактивировать (нельзя при активных абонементax).	Админ
PUT	<code>/gym/admin/class-types/{id}/schedules</code>	Заменить расписание типа занятия.	Админ
GET	<code>/gym/admin/users</code>	Список всех пользователей.	Админ
PATCH	<code>/gym/admin/users/{id}/role</code>	Изменить роль пользователя.	Админ
GET	<code>/gym/admin/reports/summary</code>	Сводный отчёт: подписки, бронирования, выручка.	Админ
GET	<code>/gym/admin/reports/sessions</code>	Отчёт по занятиям (<code>?class_type_id=...</code>).	Админ
GET	<code>/gym/admin/sessions</code>	Все занятия с деталями тренера и типа занятия.	Админ

POST `/gym/admin/class-types` — тело запроса

Поле	Тип	Обяз.	Описание
<code>title</code>	string	Да	Название типа занятия
<code>description</code>	string	Нет	Описание
<code>trainer_id</code>	UUID	Да	Тренер (роль <code>trainer</code> или <code>admin</code>)
<code>duration_minutes</code>	integer	Да	Длительность занятия (минуты)
<code>max_participants</code>	integer	Да	Максимальное количество участников
<code>base_price</code>	decimal	Да	Базовая цена
<code>currency</code>	string	Нет	Валюта (RUB по умолчанию)
<code>is_active</code>	boolean	Нет	Активен ли (по умолчанию <code>true</code>)

PUT /gym/admin/class-types/{id}/schedules — тело запроса (массив слотов)

Поле	Тип	Обяз.	Описание
weekday	integer	Да	День недели: 0 = понедельник, 6 = воскресенье
time	string	Да	Время начала в формате HH:MM

Массив полностью заменяет текущее расписание типа занятия.

15. Эндпоинты: Системный администратор

Базовый путь: `/api/v1/admin`

Все эндпоинты требуют заголовок `X-Admin-Secret`, совпадающий с переменной окружения `ADMIN_SECRET`. Сессия не требуется.

Метод	Путь	Описание	Доступ
POST	<code>/admin/revoke-access</code>	Отозвать все <code>AccessGrant</code> пользователя для указанного ресурса.	<code>X-Admin-Secret</code>

POST `/admin/revoke-access` — тело запроса

Поле	Тип	Обяз.	Описание
<code>telegram_id</code>	<code>string</code>	Да	Telegram ID пользователя
<code>resource_slug</code>	<code>string</code>	Да	Slug ресурса

Ответ

Поле	Тип	Обяз.	Описание
<code>revoked</code>	<code>boolean</code>	—	<code>true</code> , если хотя бы один грант удалён
<code>grants_removed</code>	<code>integer</code>	—	Количество удалённых грантов
<code>telegram_id</code>	<code>string</code>	—	Telegram ID
<code>resource_slug</code>	<code>string</code>	—	Slug ресурса

16. Модели данных

16.1 User

Поле	Тип	Описание
id	UUID	Первичный ключ
telephone	varchar(32)	Уникальный номер телефона
telegram_id	varchar(64)	Уникальный Telegram ID
first_name	varchar(120)	Имя
last_name	varchar(120)	Фамилия
age	integer	Возраст
gender	varchar(32)	Пол
role	enum	user / trainer / admin
created_at	timestampz	Дата создания
updated_at	timestampz	Дата обновления

16.2 Resource

Поле	Тип	Описание
id	UUID	Первичный ключ
slug	varchar	Уникальный slug
title	varchar	Название
description	text	Описание
content_url	varchar	URL защищённого контента
is_active	boolean	Активен ли

16.3 Plan

Поле	Тип	Описание
id	UUID	Первичный ключ
resource_id	UUID FK	Ресурс
code	varchar	Код (уникален в рамках ресурса)
title	varchar	Название
duration_type	enum	1m / 3m / 6m / lifetime
duration_months	integer null	Количество месяцев (null = lifetime)
price_amount	numeric	Цена

currency	varchar	Валюта
is_active	boolean	Активен ли

16.4 Order

Поле	Тип	Описание
id	UUID	Первичный ключ
user_id	UUID FK	Пользователь
resource_id	UUID FK	Ресурс
plan_id	UUID FK	План
provider	varchar	Платёжный провайдер
status	enum	pending / paid / failed / refunded

16.5 AccessGrant

Поле	Тип	Описание
id	UUID	Первичный ключ
user_id	UUID FK	Пользователь
resource_id	UUID FK	Ресурс
order_id	UUID FK	Заказ (источник)
grant_type	varchar	Тип гранта: lifetime, timed, ...
starts_at	timestampz	Начало действия
expires_at	timestampz	Конец действия (null = бессрочно)
is_lifetime	boolean	Бессрочный ли

16.6 ClassType (Тип занятия)

Поле	Тип	Описание
id	UUID	Первичный ключ
title	varchar	Название
description	text	Описание
trainer_id	UUID FK	Тренер
duration_minutes	integer	Длительность (мин.)
max_participants	integer	Макс. участников
base_price	numeric	Базовая цена
currency	varchar	Валюта
is_active	boolean	Активен ли

16.7 Subscription (Абонемент)

Поле	Тип	Описание
id	UUID	Первичный ключ
user_id	UUID FK	Пользователь
class_type_id	UUID FK	Тип занятия
period_type	enum	current_month_rest / next_month / next_3_months / next_6_months
period_start	date	Начало периода
period_end	date	Конец периода
days_count	integer	Количество дней
gross_amount	numeric	Полная сумма
discount_amount	numeric	Скидка
total_amount	numeric	Итоговая сумма к оплате
status	enum	pending_payment / active / expired / cancelled
activated_at	timestampz	Момент активации

16.8 ClassSession (Занятие)

Поле	Тип	Описание
id	UUID	Первичный ключ
class_type_id	UUID FK	Тип занятия
trainer_id	UUID FK	Тренер

scheduled_at	timestampz	Дата/время начала
ends_at	timestampz	Дата/время конца
duration_minutes_snapshot	integer	Снимок длительности на момент создания
max_participants_snapshot	integer	Снимок макс. участников
status	enum	scheduled / completed / cancelled

16.9 Booking (Бронирование)

Поле	Тип	Описание
id	UUID	Первичный ключ
user_id	UUID FK	Пользователь
class_session_id	UUID FK	Занятие
subscription_id	UUID FK	Абонемент
status	enum	confirmed / attended / absent / cancelled
created_at	timestampz	Дата создания

16.10 DiscountCredit (Скидочный кредит)

Поле	Тип	Описание
id	UUID	Первичный ключ
user_id	UUID FK	Пользователь
amount	numeric	Сумма кредита
currency	varchar	Валюта
is_used	boolean	Использован ли
applied_to_subscription_id	UUID FK	Абонемент, к которому применён
reason	varchar	Причина начисления

17. Фоновые задачи (Celery)

Celery-воркер использует Redis в качестве брокера и бэкенда результатов. Задачи запускаются автоматически из обработчика webhook.

<code>process_payment_webhook_task</code>	Принимает <code>event_id</code> . Обработывает платёжное событие в фоне после подтверждения оплаты: дополнительное логирование и бизнес-логика.
---	---

18. Проверка здоровья сервиса

Эндпоинт GET /health не требует аутентификации и возвращает HTTP 200. Используется для healthcheck в Docker, Railway и других платформах.

```
GET /health
```

```
Response 200 OK: {"status": "ok"}
```

Gym Backend API | v0.1.0 | Май 2026